

Universidad Mariano Gálvez de Guatemala
Centro Universitario El Naranjo, Mixco
Facultad de Ingeniería en Sistemas de Información
Ingeniería en Ciencias y Sistemas
Seguridad y Auditoría de Sistemas

SEGUNDO ENTREGABLE DEL PROYECTO DE CURSO

MarketGT: Plataforma de Comercio Electrónico con Seguridad Gestionada para la Pequeña Empresa

*Modelo de negocio, problema de seguridad, solución tecnológica
e implementación de estándares*

Integrantes

Diego Antonio Beteta García — 9490-22-12878
Jonathan Rogelio Herrera Soto — 9490-22-11551
Mario Roberto Rompich Yoc — 9490-17-1752

Guatemala, 26 de septiembre de 2026

Introducción

El presente documento constituye el segundo entregable del proyecto de curso y desarrolla cuatro aspectos de la propuesta: el modelo de negocio con su segmento de mercado, el problema de seguridad que la solución atiende tanto en el plano de los sistemas físicos y lógicos como en el de la información, la solución tecnológica adoptada, y la implementación de los estándares y buenas prácticas que la rigen.

A diferencia del primer entregable, que planteaba la propuesta en términos de diseño, este documento describe una plataforma que fue efectivamente construida y desplegada en un entorno público accesible. Las afirmaciones que siguen pueden verificarse sobre ese entorno, y a lo largo del texto se indican los puntos donde esa verificación es posible.

El proyecto incorpora además un caso real. Durante su desarrollo, uno de los integrantes identificó que el sitio corporativo de la empresa donde labora presentaba un envenenamiento de posicionamiento en buscadores, un ataque que ninguna de las plataformas de comercio electrónico consultadas contempla entre sus controles. Ese hallazgo orientó una parte sustantiva de la solución y se documenta en la sección correspondiente.

1. Modelo de Negocio

1.1 Descripción general

MarketGT es una plataforma de comercio electrónico ofrecida bajo el modelo de software como servicio. El comerciante no adquiere licencias, no administra infraestructura y no contrata personal técnico: contrata un servicio mensual que incluye la tienda en línea y, de forma indisociable, los controles de seguridad que la protegen.

La propuesta de valor no es la tienda. Existen numerosas plataformas que resuelven el catálogo, el carrito y el proceso de compra, y varias lo hacen mejor. La propuesta de valor es que la seguridad deje de ser una responsabilidad del comerciante, porque el segmento al que se dirige la plataforma carece por completo de la capacidad de asumirla.

1.2 Segmento de mercado

El segmento se define con precisión deliberada, dado que la viabilidad de la propuesta depende de atender a quien no puede resolver el problema por su cuenta:

Tabla 1
Definición del segmento objetivo

Dimensión	Definición
Tipo de organización	Pequeña y mediana empresa formalmente constituida
Tamaño	Entre uno y veinte empleados
Ubicación	República de Guatemala, con énfasis en área metropolitana y cabeceras departamentales
Canal actual de venta	Redes sociales y mensajería instantánea, sin tienda propia
Personal técnico	Ninguno dedicado a tecnología o seguridad
Presupuesto mensual de tecnología	Inferior a mil quetzales
Facturación	Obligada al régimen de factura electrónica en línea
Medio de pago predominante	Transferencia, depósito y pago contra entrega

Nota. El segmento se acota por capacidad de respuesta ante un incidente y no por volumen de ventas, porque es esa capacidad la que determina la necesidad que la plataforma atiende.

1.3 Por qué este segmento y no otro

Tres razones sostienen la elección. La primera es de exposición: una organización de este tamaño publica una aplicación en Internet con la misma superficie de ataque que una grande, pero sin ninguna de sus capacidades defensivas. La segunda es de incentivo: una plataforma internacional cobra en divisa extranjera más una comisión por transacción, lo que introduce exposición cambiaria mensual en un negocio de márgenes estrechos. La tercera es de cumplimiento: los requisitos de facturación electrónica y las obligaciones sobre datos personales aplican con independencia del tamaño, y una plataforma extranjera no los contempla.

El segmento resulta así definido por una asimetría concreta: enfrenta las mismas amenazas que una empresa grande, con una fracción de sus recursos y ninguna de sus capacidades.

1.4 Misión, visión y objetivos

Misión. Permitir que una pequeña empresa guatemalteca venda en línea sin necesidad de adquirir competencias en seguridad informática, trasladando esa responsabilidad a la plataforma.

Visión. Constituirse en la plataforma de referencia del mercado regional para el comercio electrónico de pequeña escala, distinguida por la verificabilidad de sus controles antes que por la extensión de sus funciones.

Los objetivos que rigen la operación son cuatro: sostener la continuidad del servicio frente a interrupciones, mitigar las vulnerabilidades de la capa de aplicación, proteger las credenciales y la información de pago de los clientes del comerciante, y sostener la mejora continua mediante auditoría periódica de los controles implementados.

2. Problema de Seguridad

El problema se analiza en los dos planos que solicita el enunciado: el de los sistemas, comprendiendo sus componentes físicos y lógicos, y el de la información que esos sistemas custodian.

2.1 Plano de los sistemas: componentes físicos

La plataforma opera sobre infraestructura virtualizada contratada a un proveedor de nube, de modo que el equipo del proyecto no ejerce control físico sobre el equipamiento. Esta circunstancia desplaza el perímetro de seguridad: el punto de exposición deja de ser una instalación con control de acceso físico y pasa a ser la interfaz de red publicada en Internet.

Las amenazas relevantes en este plano son la exposición de servicios que no deberían ser alcanzables desde el exterior, el acceso remoto no autorizado al sistema operativo, y la indisponibilidad por agotamiento de los recursos de cómputo. Conviene señalar que la responsabilidad sobre la seguridad física del equipamiento corresponde al proveedor de infraestructura, mientras que la configuración del sistema operativo y de los servicios expuestos corresponde íntegramente al equipo del proyecto.

2.2 Plano de los sistemas: componentes lógicos

La superficie de ataque de mayor exposición es la aplicación web, accesible de forma permanente y sin autenticación previa en su catálogo público. Los datos de la infografía de vulnerabilidades analizada en el curso permiten ordenar las amenazas por frecuencia observada:

Tabla 2

Amenazas de la capa de aplicación ordenadas por frecuencia

Amenaza	Frecuencia	Categoría OWASP Top 10:2025	Consecuencia
Cross-Site Scripting	14.69 %	A05:2025 Inyección	Secuestro de sesión e inyección de contenido
Componentes vulnerables	12.36 %	A03:2025 Cadena de suministro	Ejecución remota mediante dependencias
Autenticación débil	9.25 %	A07:2025 Fallas de autenticación	Suplantación de cuentas
Inyección SQL	5.55 %	A05:2025 Inyección	Extracción de la base de datos
Configuración insegura	No cuantificada	A02:2025 Configuración incorrecta	Exposición de servicios y datos

Nota. Los porcentajes proceden de la infografía de vulnerabilidades web analizada en el curso. La correspondencia con las categorías vigentes se establece a partir de la clasificación publicada por la Fundación OWASP para 2025, en la que las secuencias de comandos en sitios cruzados quedaron consolidadas dentro de la categoría de inyección.

A estas amenazas se suma una que la literatura de comercio electrónico rara vez contempla y que este proyecto incorpora a partir de un caso observado: la manipulación del posicionamiento en buscadores.

2.3 Caso observado: envenenamiento de posicionamiento

Durante el desarrollo del proyecto se identificó que el sitio corporativo de una empresa guatemalteca dedicada a la comercialización e instalación de sistemas de videovigilancia presentaba un patrón anómalo en su consola de resultados de búsqueda. El dominio se mostraba en los resultados del buscador para consultas que no guardaban relación alguna con su actividad comercial.

Tabla 3

Consultas observadas en la consola de búsqueda del caso analizado

Consulta	Impresiones	Clics	Relación con el negocio
cámaras de seguridad guatemala	8	1	Legítima
mantenimiento de cámaras de seguridad	1	1	Legítima
p9bet login	45	0	Ninguna: marca de apuestas
0016bet	13	0	Ninguna: marca de apuestas
96n.com	11	1	Ninguna: dominio de terceros
kmj888	10	0	Ninguna: marca de apuestas

Nota. El dominio se omite por tratarse de una empresa real cuyo sitio permanece comprometido. La desproporción entre impresiones y clics constituye la señal diagnóstica: quien busca una marca de apuestas y encuentra una empresa de videovigilancia no selecciona el resultado, de manera que el buscador está mostrando el dominio por contenido que no le pertenece.

El mecanismo del ataque consiste en alojar contenido ajeno en un dominio con reputación establecida, de modo que el atacante aprovecha esa reputación para posicionar sus propios sitios. Su gravedad para una pequeña empresa es considerable y de naturaleza distinta a la de una filtración de datos: el posicionamiento en buscadores representa años de construcción y constituye con frecuencia el principal canal de captación, mientras que su recuperación tras una penalización se mide en meses.

La característica que vuelve este ataque particularmente insidioso es que resulta invisible para el propietario del sitio. El atacante puede servir contenido diferenciado según quién realice la petición, de manera que el responsable navega su sitio sin advertir anomalía alguna mientras el buscador indexa contenido distinto.

2.4 Plano de la información

La información que la plataforma custodia se clasifica en tres categorías según el impacto de su divulgación no autorizada:

Tabla 4
Clasificación de la información custodiada

Categoría	Contenido	Impacto de su divulgación
Credenciales de acceso	Contraseñas, secretos de segundo factor, códigos de recuperación	Crítico: permite suplantación y acceso a todo lo demás
Medios de pago	Datos de tarjeta empleados en el proceso de compra	Crítico: fraude directo y responsabilidad legal
Datos personales	Nombre, dirección de entrega, teléfono, correo	Alto: exposición de terceros ajenos a la decisión
Información comercial	Catálogo, precios, historial de pedidos	Medio: ventaja competitiva y perfilado de clientes

Debe subrayarse una asimetría que define la obligación de la plataforma: la información comprometida no pertenece al comerciante, sino a sus clientes, quienes no participaron en la decisión de contratar el servicio ni pueden evaluar su seguridad. Esa circunstancia traslada la responsabilidad a quien sí puede evaluarla, que es la plataforma.

3. Solución Tecnológica

3.1 Principio rector

La solución adopta un esquema de defensa en profundidad organizado en seis capas concéntricas que rodean el activo protegido, que son los datos de los clientes. El supuesto de diseño consiste en asumir que cualquier capa puede fallar, de manera que ninguna concentra por sí sola la seguridad del sistema. Un atacante que vulnere el perímetro debe todavía superar el cortafuegos de red, el endurecimiento del sistema operativo, el cortafuegos de aplicación, los controles de la aplicación y, finalmente, el cifrado de los datos.

3.2 Capas del esquema

Tabla 5
Controles implementados por capa

Capa	Componente	Control	Amenaza que mitiga
1 · Perímetro	Cloudflare	Mitigación de denegación de servicio, red de entrega, límite de tasa	Tráfico automatizado y saturación
2 · Red	UFW y fail2ban	Solo 80 y 443 abiertos; acceso remoto por llave; bloqueo automático	Escaneo y fuerza bruta
3 · Sistema operativo	Ubuntu Server LTS	Endurecimiento CIS, parcheo automático, auditoría inmutable	Escalada de privilegios
4 · Cortafuegos de aplicación	Nginx, ModSecurity 3, OWASP CRS 4.29	Inspección de capa 7 con puntuación de anomalía	Inyección SQL, XSS, recorrido de rutas
5 · Aplicación	Laravel 13	Segundo factor, control por roles, validación, cabeceras	Control de acceso roto y secuestro
6 · Datos	MariaDB	Cifrado en reposo, tokenización, respaldo externo cifrado	Exfiltración de información sensible

Nota. La capa de perímetro quedó implementada de forma parcial en el entorno publicado. Los proveedores de dominio gratuito compatibles con el servicio de borde requieren aprobación manual con plazos superiores al horizonte del proyecto. La limitación se declara de forma expresa y se documenta en el registro de decisiones de arquitectura, con sus mitigaciones en capas inferiores y el riesgo residual aceptado.

3.3 El cortafuegos de aplicación como control central

El control central de la propuesta es un cortafuegos de aplicación web construido sobre ModSecurity 3 con el Core Rule Set de OWASP, desplegado como proxy inverso delante de la aplicación. Su elección responde a que constituye un control compensatorio: protege la aplicación incluso cuando su código contiene un defecto todavía no corregido, lo que resulta decisivo en una plataforma que publica actualizaciones con frecuencia.

La red que comunica el cortafuegos con la aplicación se declara como interna, de modo que no existe ninguna ruta hacia la aplicación que no atraviese el cortafuegos. Esta propiedad puede verificarse desde el exterior mediante descubrimiento de puertos, y constituye evidencia auditable de que el control no puede eludirse.

El motor opera con nivel de paranoia uno para el bloqueo y nivel dos para la detección. La distinción es deliberada: el segundo nivel registra eventos adicionales que alimentan el panel de monitoreo sin elevar el riesgo de interrumpir tráfico legítimo. Un cortafuegos que bloquea todo cuanto detecta interrumpe la operación del comercio; uno que solo registra lo que bloquea deja ciego al equipo de detección.

3.4 Reglas propias contra la manipulación del posicionamiento

El Core Rule Set no contiene reglas orientadas a la manipulación del posicionamiento, y no existe complemento oficial que las aporte. El conjunto de reglas cubre la vía de entrada de un ataque, como la inyección o las secuencias de comandos, pero no el objetivo de quien busca envenenar el posicionamiento de un dominio ajeno.

El equipo desarrolló en consecuencia veinticuatro reglas propias, identificadas en el rango reservado para uso local, que cubren la detección de rastreadores falsificados, el contenido diferenciado, la inyección de enlaces publicitarios, el abuso de redirección abierta y la extracción masiva de contenido. Durante las pruebas realizadas sobre el entorno publicado,

una de estas reglas propias resultó ser la de mayor número de activaciones del conjunto completo.

La verificación de rastreadores merece una precisión metodológica. Comprobar que una petición que se identifica como rastreador de un buscador procede efectivamente de él exige resolver el nombre inverso de la dirección y verificar después que ese nombre resuelve de vuelta a la misma dirección. Esa comprobación no puede realizarse dentro de una regla de ModSecurity, dado que el motor no admite consultas de nombres síncronas, razón por la cual la regla del cortafuegos contrasta contra los rangos publicados por los buscadores y la verificación completa se delega a la aplicación.

3.5 Autenticación de la capa de aplicación

La autenticación combina la contraseña con dos métodos alternativos de segundo factor. El primero es la contraseña de un solo uso basada en tiempo definida en el RFC 6238, seleccionada por su amplia compatibilidad con las aplicaciones autenticadoras que los usuarios ya emplean. El segundo son las credenciales de clave pública de la especificación WebAuthn, conocidas comercialmente como passkeys.

La incorporación del segundo método responde a una limitación del primero que conviene declarar: una contraseña de un solo uso que el usuario transcribe manualmente no es resistente a la suplantación de sitio, puesto que un atacante que controle una página falsa puede solicitarla y retransmitirla al servicio legítimo. Las credenciales de clave pública vinculan criptográficamente la autenticación con el sitio para el que fueron creadas, de modo que en un sitio impostor el navegador ni siquiera las ofrece.

Los códigos de recuperación completan el esquema como mecanismo de continuidad, y conviene precisar que no constituyen un tercer método de autenticación sino una salida controlada para recuperar el acceso cuando el segundo factor no está disponible.

3.6 Detección y respuesta

El anexo del primer entregable, elaborado a partir del modelo del triángulo de la ciberresiliencia, identificó que la propuesta original desarrollaba el vértice de protección, instrumentaba parcialmente el de detección y dejaba ausente el de respuesta. La solución construida atiende esa observación.

La detección se implementa mediante un panel propio que ingiere el registro de auditoría del cortafuegos, el registro de la aplicación y el del sistema operativo, los normaliza en un modelo común de eventos y los evalúa contra reglas de correlación con umbrales declarados. Cada coincidencia genera una alerta con severidad, evidencia y acción recomendada, y cada alerta transita por estados de atención. Esa transición es lo que distingue una herramienta encendida de un servicio operado.

El panel vigila además su propia fuente de datos. Cuando la ingesta permanece detenida más allá de un umbral, lo advierte de forma expresa, en atención a que un tablero sin eventos resulta ambiguo: puede indicar ausencia de incidentes o ausencia de alimentación, y son situaciones opuestas. Durante el desarrollo, esa advertencia detectó efectivamente que las tareas de ingesta no estaban programadas.

La respuesta se sostiene en un plan de respuesta a incidentes conforme a la guía NIST SP 800-61, con procedimientos diferenciados por tipo de incidente, matriz de escalamiento, respaldo diario cifrado hacia almacenamiento externo y prueba de restauración verificada.

3.7 Verificabilidad

La plataforma se encuentra desplegada en un entorno público con certificado de transporte válido. Las afirmaciones de esta sección pueden comprobarse de forma directa: el bloqueo de una inyección devuelve el código de respuesta correspondiente junto con el identificador de la regla activada y la puntuación acumulada; los eventos aparecen en el panel

de monitoreo con su origen y su severidad; y el descubrimiento de puertos desde el exterior confirma que únicamente los puertos del servicio web resultan alcanzables.

4. Implementación de Estándares y Buenas Prácticas

4.1 Marco rector

El proyecto adopta la norma ISO/IEC 27001:2022 como marco rector, dado que establece los requisitos de un sistema de gestión de la seguridad de la información y organiza en su Anexo A un total de noventa y tres controles agrupados en cuatro temas. Sobre ese marco se apoyan estándares complementarios que aportan el detalle técnico que la norma deliberadamente no especifica.

Tabla 6

Estándares aplicados y su función en el proyecto

Estándar	Ámbito	Aplicación concreta
ISO/IEC 27001:2022	Sistema de gestión	Marco rector y selección de controles del Anexo A
ISO/IEC 27002:2022	Guía de implementación	Criterios de configuración y de registro de eventos
OWASP Top 10:2025	Riesgos de aplicaciones web	Catálogo de amenazas que el cortafuegos debe detectar
OWASP Core Rule Set 4.29	Reglas genéricas de detección	Reglas cargadas y ajuste del umbral de anomalía
PCI DSS v4.0, requisito 6.4.2	Protección de datos de tarjeta	Obliga al despliegue del cortafuegos de aplicación
CIS Benchmark para Ubuntu	Endurecimiento del sistema	Línea base verificable de configuración
NIST SP 800-61	Gestión de incidentes	Estructura del plan de respuesta y escalamiento
NIST SP 800-63B	Identidad digital	Requisitos de los autenticadores y limitación de intentos
RFC 6238	Contraseña de un solo uso	Algoritmo del segundo factor basado en tiempo
W3C WebAuthn	Credenciales de clave pública	Segundo factor resistente a suplantación de sitio

Nota. Los estándares se aplican de forma complementaria: la norma ISO/IEC 27001 establece qué debe gestionarse, mientras que OWASP, CIS, NIST y las especificaciones técnicas precisan cómo hacerlo.

4.2 Correspondencia entre amenazas y controles

Tabla 7

Trazabilidad entre las amenazas identificadas y los controles implementados

Amenaza	Control implementado	Control del Anexo A
Cross-Site Scripting	Reglas 941 del Core Rule Set y política de contenido	8.26

Amenaza	Control implementado	Control del Anexo A
Componentes vulnerables	Parcheo automático y auditoría de dependencias	8.8
Autenticación débil	Segundo factor, limitación de intentos y bloqueo automático	8.5
Inyección SQL	Reglas 942 del Core Rule Set y sentencias preparadas	8.26, 8.28
Configuración insegura	Endurecimiento CIS y auditoría periódica	8.9
Manipulación del posicionamiento	Reglas propias y verificación de rastreadores	8.16
Exfiltración de datos	Cifrado en reposo y tokenización	8.24
Detección tardía	Correlación de eventos y alertas con umbral	8.15, 8.16
Ausencia de respuesta	Plan de respuesta y matriz de escalamiento	5.24 a 5.28
Pérdida de información	Respaldo cifrado externo y prueba de restauración	8.13

4.3 Defensa en profundidad verificable

La correspondencia anterior evidencia una propiedad que conviene destacar: varias amenazas cuentan con más de un control, situados en capas distintas y funcionando de forma independiente. La inyección SQL constituye el ejemplo más claro. El cortafuegos de aplicación la detecta en la capa cuatro mediante análisis del contenido de la petición, mientras que la aplicación la neutraliza en la capa cinco mediante sentencias preparadas con parámetros ligados. Ambos controles operan sin conocimiento el uno del otro, de manera que el fallo de cualquiera de ellos no compromete la protección.

Esta redundancia produjo durante el desarrollo un efecto que merece consignarse, por cuanto ilustra una consecuencia real de la defensa en profundidad que la literatura rara vez menciona: el cortafuegos de la capa cuatro bloqueaba el contenido malicioso de prueba antes de que el sanitizador de la capa cinco pudiera procesarlo, de modo que impedía demostrar el funcionamiento del segundo. La resolución consistió en relajar únicamente la evaluación de anomalía en las rutas de demostración, conservando la evaluación de las reglas y su registro en la bitácora de auditoría, lo que constituye una excepción documentada y no una desactivación del control.

4.4 Declaración de alcance y limitaciones

El proyecto declara de forma expresa aquello que no cubre, en atención a que una declaración de aplicabilidad que afirme la totalidad de los controles resulta menos creíble que una que reconozca sus límites.

La capa de perímetro quedó implementada de forma parcial por las razones técnicas expuestas. El panel de monitoreo emplea una implementación propia en lugar de una solución comercial de gestión de eventos, decisión fundada en que las métricas del modelo adoptado se calculan sobre el modelo de datos específico de la plataforma. Y cuatro de las ocho métricas del panel se declaran sin datos, por cuanto dependen de registros que no residen en la plataforma o de procedimientos cuya ejecución debe ocurrir antes de poder medirse.

Esta última declaración constituye una decisión deliberada de diseño. El panel podría estimar esas cifras y presentaría un aspecto más favorable, pero una métrica calculada sobre supuestos no permite decidir, y su presencia invalidaría la credibilidad de las restantes. La distinción entre lo que se mide y lo que se supone es, precisamente, lo que un sistema de gestión de la seguridad de la información aporta sobre un conjunto de herramientas.

Conclusiones

La definición precisa del segmento resultó determinante para la coherencia de la propuesta. Acotar el mercado a la pequeña empresa guatemalteca sin personal técnico permitió establecer que la propuesta de valor no reside en las funciones de la tienda, donde la competencia es superior, sino en trasladar a la plataforma una responsabilidad que el segmento no puede asumir.

El caso de envenenamiento de posicionamiento observado durante el desarrollo modificó el alcance del proyecto. Se trata de una amenaza que las plataformas consultadas no contemplan, que afecta al activo más costoso de reconstruir para un negocio pequeño, y que resulta invisible para el propietario del sitio. Las reglas desarrolladas para atenderla constituyen el aporte más específico del trabajo, por cuanto cubren un ámbito para el que no existe conjunto de reglas público.

La construcción efectiva de la plataforma reveló propiedades de la defensa en profundidad que el diseño en papel no anticipaba. La más instructiva fue la interferencia entre controles de capas distintas que detectan la misma amenaza, cuya resolución exige criterio para documentar excepciones acotadas en lugar de desactivar controles.

Finalmente, la decisión de declarar cuatro métricas sin datos, en lugar de estimarlas, sintetiza el criterio que gobierna el proyecto. Un sistema de gestión de la seguridad de la información se distingue de un conjunto de herramientas en que sabe qué mide y reconoce qué ignora.

Referencias

Center for Internet Security. (2025). CIS Ubuntu Linux benchmark.

https://www.cisecurity.org/benchmark/ubuntu_linux

M'Raihi, D., Machani, S., Pei, M., y Rydell, J. (2011). TOTP: Time-based one-time password algorithm (RFC 6238). Internet Engineering Task Force. <https://www.rfc-editor.org/rfc/rfc6238>

National Institute of Standards and Technology. (2025). Digital identity guidelines: Authentication and lifecycle management (NIST SP 800-63B-4). U.S. Department of Commerce.

Nelson, A., Rekhi, S., Souppaya, M., y Scarfone, K. (2025). Incident response recommendations and considerations for cybersecurity risk management (NIST SP 800-61r3). National Institute of Standards and Technology.

Organización Internacional de Normalización. (2022). ISO/IEC 27001:2022. Seguridad de la información, ciberseguridad y protección de la privacidad. Sistemas de gestión de la seguridad de la información. Requisitos.

Organización Internacional de Normalización. (2022). ISO/IEC 27002:2022. Controles de seguridad de la información.

OWASP Foundation. (2025). OWASP Top 10:2025. <https://owasp.org/Top10/2025/>

OWASP Foundation. (2026). OWASP Core Rule Set. <https://corerulest.org/>

PCI Security Standards Council. (2024). Payment Card Industry Data Security Standard: Requirements and testing procedures (v4.0.1).

Rompich Yoc, M. R., Herrera Soto, J. R., y Beteta García, D. A. (2026). Propuesta de solución de seguridad para una plataforma de comercio electrónico (E-Commerce)

SaaS): Implementación de un Web Application Firewall bajo la norma ISO/IEC 27001 [Proyecto de curso]. Universidad Mariano Gálvez de Guatemala.

World Wide Web Consortium. (2026). Web Authentication: An API for accessing public key credentials — Level 3. <https://www.w3.org/TR/webauthn/>